

OMNIINTELOS S.A.

Security Incident Post-Mortem

INC-2023-0214 - Staging estate intrusion

Incident ID	INC-2023-0214
Severity	SEV-1 (Critical)
Detected	2023-02-14 02:41 UTC
Contained	2023-02-16 19:05 UTC
Closed	2023-05-31
Author	Security & Compliance, OmniIntelOS S.A.
Classification	Internal - restricted

OmniIntelOS S.A. is a fictional company. This document is generated for IntelAI demonstration and evaluation purposes.

1. Executive summary

Between 13 and 16 February 2023 an external actor obtained valid credentials to a staging environment that held a replicated subset of customer telemetry. The intrusion was detected by anomalous egress volume, contained within 65 hours, and did not reach production customer databases. Three privacy incidents were formally notified to affected customers and to the supervisory authority.

Measured impact

February 2023 uptime fell to 96.42% against a 99.95% target. Critical vulnerabilities peaked at 31. Monthly logo churn rose to 2.80% by April as affected customers exercised termination rights, and net revenue retention bottomed at 97.3%.

2. Timeline

Timestamp (UTC)	Event
2023-02-13 21:14	Credential-stuffing attempts begin against the staging SSO endpoint.
2023-02-13 23:02	Valid session established using a re-used contractor credential; MFA not enforced on staging.
2023-02-14 02:41	Egress anomaly detection fires: 4.2 GB outbound from a staging subnet.
2023-02-14 03:10	On-call SRE escalates to SEV-1; incident channel opened.
2023-02-14 05:55	Staging estate isolated from the transit VPC. Customer-facing degradation begins.
2023-02-14 11:20	Forensic imaging starts; external DFIR retained.
2023-02-15 08:00	Scope confirmed: staging telemetry replica only; production RDS untouched.
2023-02-15 16:30	Global credential rotation; MFA enforced on all non-production estates.
2023-02-16 19:05	Containment declared. Phased service restoration begins.
2023-02-20	Customer notifications dispatched (EN/FR); regulator notified within 72h.
2023-03-06	Independent penetration test commissioned.
2023-05-31	All 14 remediation actions closed; incident formally closed.

3. Root cause

Three independent control failures had to coincide. None alone would have produced the incident, which is why none was caught by the controls that existed at the time.

- Non-production estates were exempt from the MFA policy that covered production, on the assumption that staging held no customer data. That assumption had silently stopped being true when a telemetry replication job was pointed at staging in Q3 2022.
- A contractor credential issued in 2021 was never revoked at contract end; the joiner-mover-leaver process covered employees but not contractors.
- Egress monitoring alerted on volume but not on destination reputation, so the first 3.5 hours of exfiltration to a known-bad ASN did not raise an alert.

4. Cascade into other domains

The incident is the clearest example in the company's history of single-domain failure propagating across the business, and the monthly KPI series records each step.

Month	Uptime %	SLA %	Logo churn %	NRR %	Revenue (USD)	Health
2023-01	99.83	98.8	2.47	97.4	676,785	47
2023-02	96.42	68.0	2.78	97.3	656,747	31

Month	Uptime %	SLA %	Logo churn %	NRR %	Revenue (USD)	Health
2023-03	98.15	78.4	2.28	97.9	655,399	30
2023-04	99.65	96.3	2.80	97.4	652,146	39
2023-05	99.67	96.3	2.20	97.9	654,978	36
2023-06	99.84	98.8	1.56	99.6	662,438	57
2023-07	99.87	99.4	1.07	99.5	671,614	68

5. Remediation actions

#	Action	Owner	Status
1	Enforce MFA on every estate including non-production	Security	Closed 2023-02-15
2	Extend joiner-mover-leaver to contractors and service accounts	People + Security	Closed 2023-03-02
3	Destination-reputation egress filtering	Cloud Ops	Closed 2023-03-17
4	Prohibit customer data in non-production; automated scanner	Data Platform	Closed 2023-04-11
5	Zero-trust segmentation between estates	Cloud Ops	Closed 2023-05-08
6	Independent penetration test, annual cadence	Security	Closed 2023-05-22
7	ISO 27001 programme initiation	Compliance	Closed 2023-05-31

6. What we would not change

Isolating the staging estate at 05:55 on 14 February caused most of the measured customer-facing degradation that month. It was the correct call and would be made again: the alternative was leaving a confirmed active intrusion connected to the transit network while forensics ran.